

Research proposal: Insider-related cyber security risk with Bayesian networks

Jan Ruijgrok

Open Universiteit of the Netherlands

Abstract

Cyber security incidents are difficult to model statistically because breach and insider-threat data are scarce and rarely shared. Bayesian Networks (BNs) are nevertheless widely used in this domain because they combine expert knowledge with limited evidence and support inference under partial observability. Following a systematic review of standard BN models in cyber security (Chockalingam et al., 2017), this project develops a compact, causally motivated BN (8 nodes) for malicious insider-related security risk in an organizational IT environment. The central objective is to assess whether a manually designed BN yields both (i) plausible probabilistic inferences and (ii) competitive classification performance relative to learned structures and a naive Bayes baseline. Methodologically, the proposal follows the course assignment: (1) design and validation of an original BN in pyAgrum, (2) structure-learning experiments at $n = 100, 500$, and 1000 , and (3) classifier comparison using ROC/AUC.

Background

Chockalingam et al. (2017) identified 17 standard BN models in cyber security and analysed them on eight characteristics (data sources, node count, threat actor, application, variable scope, validation, and purpose). Key findings: expert knowledge dominates CPT specification; models focus disproportionately on *malicious insiders*; variables often span People–Process–Technology; most models remain small (<40 nodes). Integrated insider–outsider models are largely absent—a gap this compact model acknowledges but does not fully address.

Representative insider work includes psychosocial precursors (Greitzer et al., 2012) and multi-indicator threat models (Axelrad et al., 2013). This project abstracts that logic into an 8-node DAG suitable for the assignment: interpretable structure, expert CPTs, synthetic learning experiments, and classifier benchmarking. Foundations: Koller & Friedman (2009); Scutari & Denis (2021).

Research questions

Working hypothesis: A domain-informed causal BN is an interpretable baseline for insider-related incident risk; structure learning adds recovery and predictive value mainly at larger n .

- **RQ1 (Model validity):** Does the manual BN yield plausible marginals, conditionals, and coherent effects for $P(\text{InsiderThreatIncident} = \text{yes} \mid \text{evidence})$?
- **RQ2 (Structure learning):** How well do search-and-score and constraint-based methods recover the true structure at $n = 100, 500$, and 1000 ?
- **RQ3 (Classification):** How do ROC/AUC compare for the original BN, a learned BN, and naive Bayes on a held-out set?
- **RQ4 (Noisy-OR):** Does noisy-OR parameterization of `InsiderThreatIncident` reduce CPT complexity while preserving plausible, monotonic risk accumulation vs. a full tabular CPT?

Research methods

Method overview

Component	Specification
Target quantity	$P(\text{InsiderThreatIncident} = \text{yes} \mid \text{evidence})$; binary class InsiderThreatIncident .
Design principle	8-node causal BN; People–Process–Technology scope (Chockalingam et al., 2017).
Parameter strategy	Expert judgement, monotonic relations where appropriate, limited plausibility calibration.
Software	pyAgrum: inference, structure learning, classification.
Literature anchor	Chockalingam et al. (2017); Axelrad et al. (2013); Greitzer et al. (2012).

Variables and state spaces

Variable	States	P–P–T	Description
JobDissatisfaction	{low, medium, high}	People	Employee dissatisfaction or frustration with work or the work environment.
SecurityAwareness	{low, medium, high}	People	Employee knowledge and awareness of security risks and safe behaviour.
PolicyCompliance	{good, poor}	Process	Extent to which employees and processes adhere to security policy.
ConcerningBehaviour	{no, yes}	People	Observed behaviour suggesting possible malicious intent or misuse.
PrivilegedAccess	{appropriate, excessive}	Tech./Process	Whether access rights are appropriate for the role or excessively granted.
TechnicalControls	{weak, adequate}	Technology	Strength of preventive and detective technical measures (logging, DLP, etc.).
MonitoringAlert	{no, yes}	Technology	Whether monitoring generated an alert from behavioural or technical signals.
InsiderThreatIncident	{no, yes}	Outcome	Whether a malicious insider-related security incident occurred.

Initial causal structure

Directed arcs
JobDissatisfaction → ConcerningBehaviour; SecurityAwareness → PolicyCompliance; PolicyCompliance → PrivilegedAccess; ConcerningBehaviour → InsiderThreatIncident; PrivilegedAccess → InsiderThreatIncident; TechnicalControls → InsiderThreatIncident; TechnicalControls → MonitoringAlert; ConcerningBehaviour → MonitoringAlert.

Dissatisfaction and behaviour capture psychosocial precursors; awareness and compliance model process discipline; controls and alerts model technology; the incident node aggregates pathways to a materialized insider-related event.

Task 1: Inference in pyAgrum

Element	Operationalization
Marginals	Baseline probabilities for all nodes.
Conditionals	e.g. $P(\text{InsiderThreatIncident} \mid \text{ConcerningBehaviour}, \text{PrivilegedAccess})$.
Scenarios	Evidence propagation (e.g., alert + excessive access).
Sensitivity	Perturb key CPT entries.

Task 2.2: Learning and classification

Block	Specification
Data	Synthetic samples from ground-truth BN; structure sets $n = 100, 500, 1000$; classifier train/test split.
Algorithms	Hill climbing (search-and-score); PC-style (constraint-based).
Structure eval	Arc differences vs. ground truth (correct, missing, reversed, spurious).
Classifiers	Original BN; learned BN; naive Bayes.
Metrics	ROC/AUC (primary); optional accuracy, confusion matrix.

Positioning vs. Chockalingam et al. (2017)

Review finding	Project response
Expert-heavy CPTs	Documented expert elicitation
Malicious insider focus	Core theme
Small models	8 nodes
Insider-outsider gap	Limitation; see Future Work roadmap

Expected contributions

- Interpretable insider-risk BN with explicit P–P–T assumptions;
- Structure-learning robustness evidence at small/moderate n ;
- Comparison of causal, learned, and naive Bayes classifiers;
- Reproducible pyAgrum workflow for the course assignment.

Task 2.3: Noisy-OR (required)

Noisy-OR on InsiderThreatIncident
Activators: ConcerningBehaviour=yes, PrivilegedAccess=excessive, TechnicalControls=weak. $P(I=\text{no} \mid \cdot) = \text{leak} \times \prod_i \text{inhibition}_i$ for active causes; compare with full logistic CPT (parameter count, scenarios, response curves).

Time schedule (10 weeks)

Weeks 1–2: literature and structure; Week 3: CPTs and Task 1; Week 4: data pipeline; Weeks 5–6: learning experiments; Week 7: classifiers; Week 8: sensitivity; Weeks 9–10: report.

Risk analysis

Oversimplification of insider threat (scope boundaries); subjective CPTs (sensitivity, monotonicity); small- n instability (multiple seeds); simulation circularity (transparent protocol, interpret AUC as method comparison).

Future work and roadmap toward SOC-relevant deployment

The present project is a **proof of concept**: an interpretable, compact BN on synthetic data, not an operational SOC product. The same approach—causal structure, uncertainty, and explanations—can nonetheless support insider-threat workflows. A realistic path comprises four stages.

Stage 1 (semi-real data). Integrate HR/people signals, IAM (privileged access), GRC (compliance), and SIEM/UEBA (controls, alerts). Combine expert elicitation with limited historical cases; evaluate analyst usefulness, not only ROC on synthetic data.

Stage 2 (analyst MVP). Deliver risk scores with top causal explanations; deploy as SIEM/SOAR enrichment or a dashboard; keep human-in-the-loop. Product forms: scoring plugin, prioritisation dashboard, or what-if simulator for interventions (access review, monitoring).

Stage 3 (technical extensions). Address literature gaps (Chockalingam et al., 2017): insider-outsider models (phishing, collusion), temporal/dynamic extensions, optional attack-path layers, and sector variants (e.g., ICS).

Stage 4 (operational trust). Drift monitoring, configurable false-positive budgets, privacy governance (DPIA, data minimisation), and validation via red-team/tabletop exercises.

Carry-over from this project. The 8-node P–P–T DAG, noisy-OR incident composition, scenario/sensitivity analysis, and causal-vs.-learned comparison provide a defensible template for explainable prioritisation—provided future work secures data, workflow integration, and organisational adoption. Without those, the model remains academic regardless of network size.

References

- Axelrad, E. T., Sticha, P. J., Brdiczka, O., & Shen, J. (2013). A Bayesian network model for predicting insider threats. *IEEE Security and Privacy Workshops*, 82–89.
- Chockalingam, S., Pieters, W., Herdeiro Teixeira, A., & van Gelder, P. (2017). Bayesian network models in cyber security: A systematic review. In *Proceedings of NordSec 2017* (LNCS 10674, pp. 105–122). Springer. https://doi.org/10.1007/978-3-319-70290-2_7
- Greitzer, F. L., et al. (2012). Identifying at-risk employees: Modeling psychosocial precursors of potential insider threats. *HICSS*, 2392–2401.
- Koller, D., & Friedman, N. (2009). *Probabilistic Graphical Models*. MIT Press.
- Scutari, M., & Denis, J.-B. (2021). *Bayesian Networks: With Examples in R* (2nd ed.). Chapman and Hall/CRC.